EXPLAIN Single Sign-On with OIDC in explain english as i am beginner in user authorization

Single Sign-On (SSO) with OpenID Connect (OIDC) means you log in once with a trusted identity provider—such as Google, Microsoft, or your company's login system—and then access several apps without entering your password again. OIDC is the standard that lets apps securely ask, "Who is this user?" and receive a verified answer. [1] [2]

Simple analogy

Imagine a company receptionist:

- You show your ID once at reception.
- Reception gives you a visitor badge.
- You use that badge to enter different rooms without showing your ID again.

Here:

- **You** = the user
- **Reception** = the Identity Provider (IdP), such as Google or Microsoft Entra ID
- **Rooms** = apps like Slack, Salesforce, or an internal dashboard
- **Visitor badge** = a secure token proving you are logged in

Key terms

Term	Plain-English meaning
User	The person trying to sign in
App / Client	The website or application the user wants to use
Identity Provider (IdP)	The trusted service that verifies the user, such as Google, Microsoft, or Okta
Authentication	Proving *who you are*
Authorization	Deciding *what you are allowed to do*
ID Token	A signed digital statement from the IdP saying who the user is
SSO	Logging in once and accessing multiple connected apps

OIDC is mainly for **authentication**—confirming identity. Authorization—what permissions the user has—is often handled separately, sometimes using OAuth 2.0 access tokens or the app's own roles and policies. [3] [4]

How it works

A typical OIDC SSO flow looks like this:

1. You open an app, for example `app.example.com`.
2. The app does not ask for your password directly. Instead, it redirects you to the identity provider, such as Google or your company's login page.
3. You sign in there with your usual username, password, and possibly multi-factor authentication.
4. The identity provider checks whether you already have an active login session.
5. If yes, it does not ask for your password again; it immediately sends you back to the app with an **ID token**.
6. The app checks that the token is valid and uses information in it—such as your email, name, or user ID—to create your app session. [2] [5] [6]

What is an ID token?

An **ID token** is usually a **JWT** (JSON Web Token): a digitally signed piece of data. It commonly contains claims such as:

- Your unique user ID
- Your email address
- Your name
- When the token was issued
- When it expires
- Who issued it

The app can verify the token's signature using trusted public keys from the identity provider. This lets the app trust that the login information really came from the IdP and was not forged. [6] [2]

Why OIDC is useful

- **Fewer passwords:** You do not need a separate password for every app.
- **Better security:** Apps never see or store your main password.
- **Central control:** IT can disable access for a departing employee in one place.
- **Easier onboarding:** New users can access approved apps using their existing company account.
- **Consistent login experience:** Users see the same trusted sign-in page across apps. [7] [1]

Authentication vs. authorization

This is a common beginner confusion:

- **Authentication:** “Is this really Priya?”
- **Authorization:** “Is Priya allowed to view the admin dashboard?”

With OIDC SSO, the IdP authenticates Priya and gives the app an ID token. The app may then use its own rules—or additional token/role information—to decide what Priya can access.[4] [3]

Small example

Suppose your company uses Microsoft Entra ID:

1. You open Salesforce.
2. Salesforce redirects you to Microsoft’s login page.
3. You sign in with your work account.
4. Microsoft confirms your identity and returns an ID token to Salesforce.
5. Salesforce verifies the token and logs you in.
6. Later, when you open another connected app, Microsoft recognizes your existing session and logs you in without another password prompt.[5] [1]

In short: **OIDC SSO lets one trusted login service prove who you are, while each app trusts that proof instead of collecting your password itself.**

⁂

1. https://www.microsoft.com/en-in/security/business/security-101/what-is-openid-connect-oidc
2. https://learn.microsoft.com/en-us/entra/identity-platform/v2-protocols-oidc
3. https://developer.okta.com/blog/2019/10/21/illustrated-guide-to-oauth-and-oidc
4. https://curity.io/resources/learn/openid-connect-overview/
5. https://auth0.com/docs/authenticate/login/oidc-conformant-authentication/oidc-adoption-sso
6. https://frontegg.com/guides/oidc-authentication
7. https://duo.com/learn/what-is-oidc
8. https://www.miniorange.com/blog/single-sign-on-protocols/
9. https://frontegg.com/guides/single-sign-on-sso
10. https://securityboulevard.com/2025/08/sso-authentication-complete-guide-to-openid-saml-oauth/